

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Data-Handling Policy Template Pack

Adoptable data-handling policies: what agents may read, write, retain, and transmit. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

DATA-HANDLING POLICY TEMPLATE PACK

For AI Agents in Production Environments Version 1.0 | © 2024 | Governance & Compliance Ready

1. EXECUTIVE SUMMARY

This **Data-Handling Policy Template Pack** is a **production-ready** framework for governing AI agents processing sensitive, proprietary, or regulated data. It includes: - **Policy Gates** (pre-deployment checks) - **Audit & Compliance Trails** (immutable logs) - **Cost & Resource Controls** (budget enforcement) - **Permissioning & Access Rules** (RBAC for agents) - **Incident Response Protocol** (containment & remediation) - **Self-Assessment Checklist** (verification)

Scope: Applies to all AI agents (LLMs, RL agents, generative systems) handling data in **production environments**, including: - Customer-facing interactions - Internal decision-making systems - Data processing pipelines - Third-party integrations

Non-Scope: Research prototypes (use *Research Data Handling Guidelines* instead).

2. POLICY GATES (PRE-DEPLOYMENT CHECKS)

Before an AI agent processes data, **all** of the following must be satisfied:

2.1 Data Classification & Sensitivity Assessment

Field	Definition	Example Values
Data Type	Categorize data (PII, PHI, financial, intellectual property, etc.)	Customer_Records, Medical_Logs, Trade_Secrets
Regulatory Scope	Applicable laws (GDPR, HIPAA, CCPA, GLBA, etc.)	GDPR (Art. 6, 9), HIPAA (45 CFR §164.502), NYDFS Cybersecurity Regulation
Retention Requirement	Legal/operational data lifecycle (e.g., 7 years for tax records)	7_years, Indefinite (archival), Purged_after_30_days
Access Restrictions	Who can view/modify? (Internal-only, vendor-limited, public)	Engineering_team_only, Contractors_with_NDA, Public (anonymized)
Derivative Risk	Potential for data leakage via agent outputs (e.g., hallucinations)	Low (aggregated), Medium (individual inferences), High (direct quotes)

Action: Assign a **Risk Score (1-5)** based on the combination of sensitivity and exposure. **Score 4** requires **manual approval** from the **Data Governance Board**.

2.2 Agent Configuration Review

Field	Requirement	Template Response
Model Selection	Approved models (vendor, version, fine-tuning status)	Mistral-7B-v0.2 (LTS), Custom_fine-tuned_on_legal_data (v3.1)
Input Validation	How unsanitized data is handled (e.g., regex, whitelisting)	Block_PII_with_regex: /(?!i)\b(?:([a-z0-9_]{56})[0-9a-f]{32})\b/
Output Sanitization	Mechanisms to prevent leakage (redaction, hashing, anonymization)	Auto-redact_SSNs, Hash_email_addresses, No_raw_PII_in_logs
Fallback Mechanism	Behavior if model fails (e.g., "I can't answer that")	Graceful_decline_with_reason
Rate Limiting	Max queries per user/agent (prevent abuse)	100_requests/hour, 500_requests/day

Action: Submit to **AI Compliance Review Board** for approval.

2.3 Permissioning & RBAC Rules

Role	Permissions	Denied Actions
Data Owner	Full CRUD, audit logs, policy overrides	None
AI Agent Operator	Execute queries, monitor performance	Modify data, expose raw outputs
Compliance Auditor	Read-only access to logs, trigger audits	Alter agent behavior, bypass gates
Third-Party Vendor	Limited to approved integrations (e.g., storage, analytics)	Direct data access, modify agent logic
Guest User	Read-only, pre-approved prompts only	Upload custom data, request sensitive inferences

Implementation: - Enforce via **attribute-based access control (ABAC)**. - Log all **role changes** with **immutable timestamp**.

2.4 Cost & Resource Controls

Field	Requirement	Template Enforcement
Budget Cap	Max spend per agent/user (daily/weekly)	Agent_X: \$50/day, User_Y: \$200/week
Token Limits	Input/output token thresholds to prevent runaway costs	Max_4096_input_tokens, Max_8192_output_tokens
Priority Queues	Critical vs. non-critical workloads	Critical (bypass_cost_limits), Standard (enforced)
Alert Thresholds	Notify when spending exceeds 80% of cap	Email: security@company.com
Emergency Override	Who can temporarily increase limits?	CISO_only, On-call_engineering_manager

Action: Integrate with **financial monitoring system** (e.g., AWS Cost Explorer, custom API).

2.5 Incident Response Plan (IRP) Integration

Field	Requirement	Template Response
Detection Trigger	How incidents are flagged (e.g., anomaly detection, manual report)	Cost_spike > \$1000, PII_leakage_detected, Model_hallucination_confirmed
Escalation Path	Who gets notified (time-sensitive)	Tier 1: Security_Ops (15 min), Tier 2: Legal (1 hr), Tier 3: Board (4 hr)
Containment Actions	Immediate steps to stop leakage/abuse	Kill_agent_processes, Revoke_API_keys, Purge_compromised_data
Forensic Logging	Data captured for investigation	Full_prompt_history, Model_outputs, Network_traffic_logs
Post-Incident Review	Root cause analysis & policy updates	Weekly_IR_meeting, Updated_Policy_Gates

Action: Link to **company's IRP** (e.g., NIST SP 800-61) and conduct **tabletop exercise** annually.

3. AUDIT & COMPLIANCE TRAILS

3.1 Immutable Log Requirements

Log Type	Retention	Access Control	Format	Example Fields
Agent Execution Logs	5 years	Compliance_Auditors	JSON (W3C DIF)	timestamp, agent_id, user_id, prompt, response, tokens_used, cost, model_version
Permission Logs	7 years	Data_Owners	CSV (ISO 27001 compliant)	role_change, user, timestamp, old_permissions, new_permissions
Cost Logs	3 years	Finance_Team	Parquet (columnar storage)	agent, user, date, spend, tokens, model
Incident Logs	Indefinite	Legal + Security	XML (for legal hold)	incident_id, trigger, containment_steps, investigator, resolution

Implementation: - Use **blockchain-anchored hashing** for critical logs. - **No human-editable logs** (WORM storage).

3.2 Compliance Checklist (Per Regulation)

Regulation	Policy Mapping	Evidence Required
GDPR (Art. 5-6)	Data minimization, purpose limitation, user rights	DSAR_response_templates, Consent_logs, Data_processing_agreements
HIPAA (45 CFR §164)	Access controls, audit logs, breach notification	PHI_access_reports, Incident_notification_emails, Business_associate_contracts
CCPA	Right to delete, opt-out mechanisms	Do_not_sell_logs, User_deletion_requests
NYDFS Cybersecurity	Encryption, vulnerability management	Risk_assessment_reports, Pen_test_results
GLBA	Nonpublic personal info (NPI) protection	NPI_encryption_certificates, Third-party_vendor_contracts

Action: Automate compliance checks via tools like **OpenCompliance (OSCAL)** or **Policy-as-Code (PAC)**.

4. INCIDENT RESPONSE PROTOCOL (IRP) EXCERPT

4.1 Data Leakage Incident

Trigger: Agent outputs PII/PHI in response to a query.

Steps: 1. **Immediate Containment:** - **Stop** the agent (kubectl delete pod agent-X). - **Revoke** API keys (aws iam revoke-policy). - **Isolate** the user (IP_block + session_termination).

1. **Forensic Collection:**
2. Dump **full prompt-response history** (aws s3 cp s3://logs/agent-X/).

Capture **network traces** (tcpdump -i eth0 -w leak_trace.pcap).

Notification:

5. **Legal:** legal@company.com (within 1 hour).
6. **Regulator:** gdpr@europa.eu (if GDPR applies, within 72 hours).

Customers: affected_users@company.com (if data exposed).

Remediation:

9. **Patch** the agent (update sanitization rules).
10. **Notify** affected users (template below).

Template: Customer Notification Email `` Subject: Important Security Update - [Inc

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com